

Handwritten Reflection Question 4 Answers

PAGE No	
DATE	

Q.1. Explain the difference between authentication and authorization.
Ans. Authentication is the process of verifying the identity of a user, confirming that a person is who they claim to be. This is usually done by checking credentials such as a username and password, a PIN or a biometric.

Authorization, on the other hand, comes after authentication and determines what an already verified user is permitted to do.

Q.2. Why should passwords never be stored in plain text?
Ans.

Storing passwords in plain text means saving them exactly as the user typed them, without any transformation. If the database or storage file containing these passwords is ever stolen, leaked, or accessed by an unauthorized person, all user passwords are immediately exposed. Since, many users reuse the same passwords across multiple websites and services, such a leak can compromise not just one system but many others linked to the same user. Storing passwords in an unreadable, encoded form instead of plain text ensures that even if the storage is breached, the original passwords are not directly revealed.

Q.3). What is the purpose of password hashing?

Ans. Password hashing is the process of converting a password into a fixed length string of characters using a mathematical hash function, such that the process cannot be reversed. The purpose of hashing is to allow the system to verify a password without even storing or knowing the

PAGE NO.
 DATE
 actual password itself; during login, the entered password is hashed again and compared with the stored hash and if they match, the access is granted.

Q. 4) How does duplicate login prevention improve security?

Ans - Duplicate login prevention ensures that a single user account cannot be logged into ~~from~~ from more than one place or session at the same time. This improves security in several ways. It prevents an attacker who has stolen a valid username and password from using the account simultaneously with the real owner without detection, it reduces the risk of conflicting or unauthorized actions being performed under the same identity, and it makes suspicious activity easier to notice, and since a legitimate user would typically be aware of only one active session at a time.

Q. 5) Suggest two additional improvements for your application.

Ans - (i) Encrypting data in transit using TLS/SSL, so that even if someone ~~catches~~ intercepts the network traffic, they cannot read the actual content.

ii) Enforcing strong password policies, such as requiring minimum length and a mix of uppercase letters, numbers, symbols, etc. with limiting the rate of login attempts or account creation.